

KIIRA MOTORS CORPORATION

HEALTH AND WELLNESS MANAGEMENT SYSTEM

INFORMATION SECURITY REVIEW

Field	Detail
Document name	Information Security Review
Reference number	KMC.DQHSE.08/26-SP003
Document description	Security assessment of the Health and Wellness Management System covering identity, clinical confidentiality, data protection, audit and the remediation required before user testing
Prepared by	Akanga Andrew, Software Engineering Intern, Department of Quality, Health, Safety and Environment
Issue date	11/08/2026
Version	002
Classification	Confidential, Restricted to KMC ICT, the data protection owner and departmental management

Table of Contents

1 Introduction.....	4
1.1 Purpose.....	4
1.2 Why This System Warrants a Review.....	4
1.3 Scope.....	4
1.4 Severity Scale.....	4
2 Security Architecture.....	5
2.1 Identity and Session.....	5
2.2 Authorisation.....	5
2.3 Clinical Confidentiality.....	5
2.4 Access Logging.....	6
3 Findings.....	6
3.1 High Findings.....	6
3.2 Medium Findings.....	7
3.3 Low Findings and Observations.....	7
3.4 What Was Found To Be Sound.....	8
4 Data Protection.....	8
4.1 Obligations.....	8
4.2 Synthetic Data in Non Production.....	8
4.3 A Conflict Requiring a Decision.....	9
5 Remediation.....	9
5.1 Before User Testing.....	9
5.2 Before Real Clinical Records.....	9
5.3 Compensating Controls During Testing.....	10
6 Conclusion.....	10

List of Figures

Figure 2.1: The Four Layers Enforcing Clinical Access.....	5
--	---

List of Tables

Table 1.1: Finding Severity Definitions.....	4
Table 2.1: Clinical Access Controls and Their Assessment.....	5
Table 3.1: High Severity Findings.....	6
Table 3.2: Medium Severity Findings.....	7
Table 3.3: Low Severity Findings and Observations.....	7
Table 4.1: Data Protection Obligations and Position.....	8
Table 5.1: Remediation Required Before User Testing.....	9
Table 5.2: Remediation Required Before Any Real Clinical Record.....	9
Table 6.1: Information Security Review Sign Off.....	10

1 Introduction

1.1 Purpose

This review records the security posture of the Health and Wellness Management System as built, identifies the weaknesses that exist in it, and states what must be closed before the system is used for testing and before it is ever used for real clinical records. It is written to be usable as a working remediation plan rather than as a compliance statement.

1.2 Why This System Warrants a Review

The system holds data concerning health, which the Data Protection and Privacy Act, 2019 treats as special personal data attracting the highest protection. It holds that data about employees, on behalf of their employer. The risk therefore is not only that an outsider reads a record. It is that a colleague reads one, and that an employee suffers an employment consequence from a medical disclosure.

That shapes the whole assessment. The controls examined most closely are the ones that separate the clinical record from the rest of the organisation, and the ability of the system to say afterwards who read what.

1.3 Scope

The review covers the application as delivered. That is the sign in and session design, the authorisation model, the clinical confidentiality controls, the audit and access logging, secret handling, container construction and the handling of personal data.

The review does not cover the physical security of any hosting site, the security of the KMC network into which the system would be deployed, or the internal security of Keycloak as a product. It is not a penetration test. It is a design and implementation review conducted against the delivered source, schema, configuration and tests.

1.4 Severity Scale

Table 1.1: Finding Severity Definitions

S/N	Severity	Definition	Required Response
1	Critical	Allows an unauthorised party to read a clinical record, or to act as an authorised user	Close before any use, including testing
2	High	Materially increases the likelihood of account compromise, or removes the ability to detect misuse	Close before real clinical records are entered
3	Medium	Weakens defence in depth or the ability to investigate	Close within the first release after go live
4	Low	Hardening opportunity with limited practical exposure as deployed	Close when the affected component is next changed
5	Observation	No action strictly required. Recorded to inform later design	No deadline

2 Security Architecture

2.1 Identity and Session

Authentication is delegated entirely to Keycloak. The application never receives a password, which removes a whole category of risk and means that password policy, lockout, multi factor authentication and later corporate single sign on are configuration rather than code.

The browser holds no token. The gateway completes the sign in exchange, keeps the tokens in server side session state and issues the browser an opaque identifier in a cookie marked HttpOnly, Secure and SameSite. A token readable by any script on the page would be an unacceptable exposure in a system holding health data, and this design removes it.

Sign in uses the authorisation code flow with a proof key, so an intercepted authorisation code cannot be exchanged by another party. Session lifetime is bounded by inactivity rather than by age, which is the appropriate control for shared clinic workstations.

2.2 Authorisation

Every service validates the token independently rather than trusting the gateway to have done so. Within a service, authorisation is checked twice, once in the request handler and once in the service layer. The second check is not redundant. It protects a code path reached from a scheduled job or an internal caller that never passes through a handler.

2.3 Clinical Confidentiality

The rule that only the Health and Wellness Officer may retrieve an individual clinical record is enforced in four independent places.

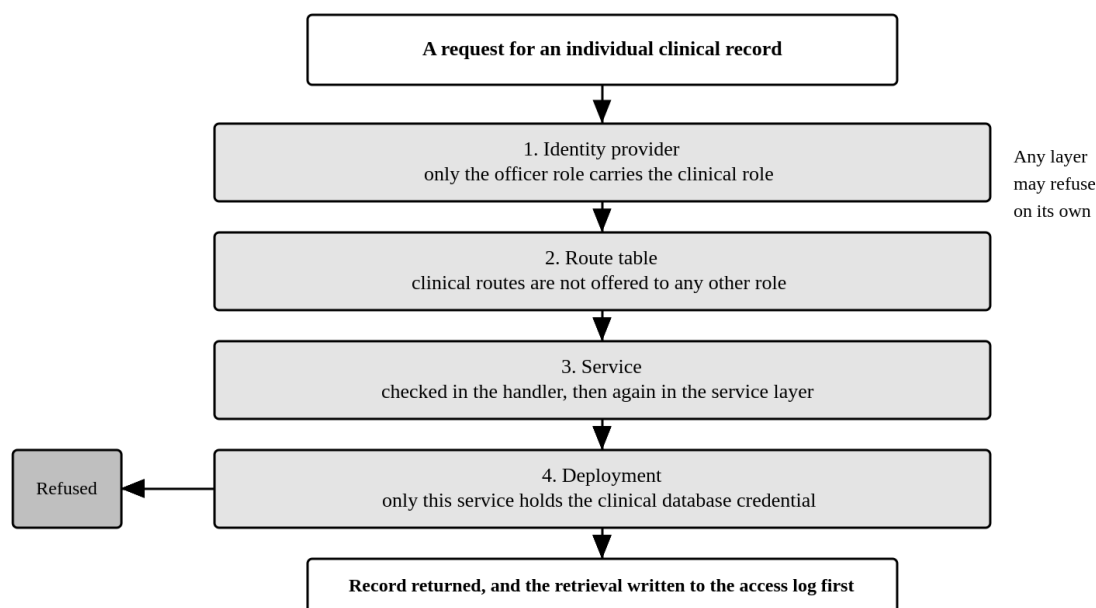


Figure 2.1: The Four Layers Enforcing Clinical Access

Table 2.1: Clinical Access Controls and Their Assessment

S/N	Layer	Control	Assessment
1	Identity provider	Only the officer role carries the clinical role	Effective
2	Route table	Clinical routes are not offered to any other role	Effective, and a courtesy rather than a control
3	Service	Role checked in the handler and again in the service layer	Effective and proved by automated test
4	Deployment	Only the clinical service holds a credential for the clinical database	Effective. Strengthened further by network policy in the cluster manifests

An automated suite asserts every clinical route against every role that is not the officer, and walks the route tree so that a route added without being covered fails the build. The suite runs against an unusable data layer, so a handler that reached data before checking the role would fail rather than pass. This is a genuine control and not a formality.

2.4 Access Logging

Ordinary audit practice logs changes. Under the Act the risk to the person arises from unauthorised reading rather than unauthorised writing, so a log that captured only changes would provide no evidence about the harm most likely to occur.

Every retrieval of an individual clinical record is therefore written to an append only access log before the record is returned. The ordering is deliberate. A log written after the response is a log that is missing precisely when a process fails mid request, which is when somebody will ask what was read. If the log cannot be written the read does not happen.

Searching the registry is logged as a retrieval, with the number of records returned, because a search by name reveals who attends the clinic just as surely as opening one record does.

3 Findings

Twelve findings were raised. None is assessed as critical. Four are high, five are medium, two are low and one is an observation. Each is stated with what was observed, why it matters operationally, and the specific change that closes it.

3.1 High Findings

Table 3.1: High Severity Findings

S/N	Reference	Finding	Impact	Remediation
1	SEC-01	Transport encryption is not configured. The delivered stack serves plain traffic	Credentials and clinical data would cross the network in the clear. The session cookie cannot be marked secure	Terminate encryption at the ingress and set the secure cookie flag. Required before any deployment beyond a laptop
2	SEC-02	Development credentials are held in the repository, including identity provider client secrets	Anyone with repository access holds the credentials of any environment that used them unchanged	Generate fresh values from a KMC controlled source. Never deploy the repository defaults
3	SEC-03	Multi factor authentication is not enabled for the officer or	A single stolen password grants either clinical access	Enable a second factor in the identity provider for both roles.

S/N	Reference	Finding	Impact	Remediation
		the manager	or the ability to create accounts	No application change required
4	SEC-04	The clinical access log has no tamper evidence beyond the database role restriction	A party with database level access could alter the record of who read what without detection	Add append only enforcement at the database and ship the log to storage the application cannot write

3.2 Medium Findings

Table 3.2: Medium Severity Findings

S/N	Reference	Finding	Impact	Remediation
1	SEC-05	Session state is held in the gateway process	A restart signs everybody out. The gateway cannot be scaled, so it is a single point of failure	Move the session store behind the existing interface to a shared store
2	SEC-06	There is no rate limit on the sign in path	Password guessing is slowed only by the identity provider lockout	Apply a rate limit at the ingress in addition to the lockout
3	SEC-07	Logs and traces are not aggregated	Investigating an incident requires reading each service separately, and log retention is not assured	Add collection to storage held outside the services
4	SEC-08	Amendment of a signed clinical record is not implemented	A correction cannot be made, so pressure will build to reopen a signed record, which would defeat the signature	Build the appended amendment before real records are entered
5	SEC-09	No automated dependency or image vulnerability scanning is configured	A known vulnerability in a dependency would not be noticed	Add scanning to the build once a pipeline exists

3.3 Low Findings and Observations

Table 3.3: Low Severity Findings and Observations

S/N	Reference	Severity	Finding	Remediation
1	SEC-10	Low	The identity provider administrative console is exposed on the same host as the application	Restrict the console to an administrative network
2	SEC-11	Low	Backups are not yet configured in any environment	Configure nightly encrypted backup, with the clinical backup under a separate key, before real records exist
3	SEC-12	Observation	The interface hides controls a role may not use rather than disabling them	No action. This is deliberate and correct, and is recorded so it is not mistaken for a gap

3.4 What Was Found To Be Sound

The following were examined and assessed as effective. They are recorded because they are the parts of a security design that are difficult to retrofit, and because a review that lists only weaknesses gives a false impression of the whole.

- Delegated authentication, so the application never handles a password.
- Tokens held server side, with the browser holding an opaque identifier only.
- Authorisation checked at two layers within each service, and proved by a suite that blocks the build.
- The clinical database as a separate instance with credentials issued to one service alone.
- Read access logging that fails the read rather than serving a record unlogged.
- Account administration performed by the service through its own account rather than by replaying the user token.
- Containers built from a minimal base, running as a non root user with a read only filesystem.
- No clinical content in any log line, metric label or trace, with route templates used as labels.

4 Data Protection

4.1 Obligations

Data concerning health is special personal data under the Act. The obligations that bear most directly on this system are lawful basis, data minimisation, the ability to report who accessed a person record, retention limits, and the security of processing.

Table 4.1: Data Protection Obligations and Position

S/N	Obligation	Position	Outstanding
1	Lawful basis and privacy notice	Not yet established	Required before real records. Owned by the data protection owner
2	Data minimisation by role	Implemented. Each role sees only what its function requires	None
3	Record of access to a person data	Implemented through the clinical access log	Tamper evidence, see SEC-04
4	Retention and disposal	Not set. No period is assumed by the system	Policy required. The system does not invent one
5	Security of processing	Partly implemented	Transport encryption and backups, see SEC-01 and SEC-11
6	Data residency	Deployed only on KMC controlled infrastructure	To be confirmed as an approved position

4.2 Synthetic Data in Non Production

No real clinical record is copied into a development, testing or demonstration environment at any point. This is stated as an absolute because it is the control most often eroded by convenience, and because a copy of clinical data taken for testing is a disclosure whatever the intention behind it.

4.3 A Conflict Requiring a Decision

The referral form requires the Head of Division and the Chief of Staff to sign a document that carries a provisional diagnosis, HIV status and mental health condition. That cannot stand alongside the rule that no management role sees an individual clinical record.

The referral authorisation view has therefore not been built. The recommendation is that authorisers see the patient, the destination facility, the reason for referral and any cost implication, and that clinical detail remains between the officer and the receiving facility. If KMC decides that authorisers do see clinical content, that is a decision the Corporation is entitled to take, and it must be taken knowingly and recorded rather than arrived at because a form was digitised as drawn.

5 Remediation

5.1 Before User Testing

User testing uses synthetic data only, so the bar is lower than for production. The following must nonetheless be closed, because testing takes place on a KMC network with real accounts held by real people.

Table 5.1: Remediation Required Before User Testing

S/N	Reference	Action	Owner
1	SEC-01	Terminate transport encryption at the ingress and set the secure cookie flag	KMC ICT
2	SEC-02	Replace every development credential with a value generated from a controlled source	KMC ICT
3	SEC-10	Restrict the identity provider administrative console to an administrative network	KMC ICT
4	None	Confirm in writing that the environment holds synthetic data only, and that participants are named	Health and Wellness Division

5.2 Before Real Clinical Records

Table 5.2: Remediation Required Before Any Real Clinical Record

S/N	Reference	Action	Owner
1	SEC-03	Enable multi factor authentication for the officer and manager roles	KMC ICT
2	SEC-04	Add tamper evidence to the clinical access log and ship it beyond the application	KMC ICT
3	SEC-08	Build appended amendment of a signed clinical record	Development
4	SEC-11	Configure nightly encrypted backup with a separate clinical key, and test a restore	KMC ICT
5	None	Establish lawful basis, privacy notice and retention policy	Data protection owner
6	None	Settle the referral authorisation conflict described in Section 4.3	Division and data protection owner
7	None	Appoint named business, technical and data owners	Department and ICT

5.3 Compensating Controls During Testing

Until the remediation in Section 5.2 is complete, the following compensating controls are proposed for the duration of user testing and should be formally adopted.

- The environment holds synthetic records only, and this is verified before each testing session rather than assumed.
- Access is restricted to named participants, and accounts are disabled at the end of testing.
- The environment is reachable only from the plant network.
- Any defect that exposes a record across roles halts testing until it is closed.

6 Conclusion

The system demonstrates a well constructed confidentiality design. Delegated authentication, tokens held away from the browser, authorisation checked twice and proved by test, a separately credentialed clinical database and access logging that refuses to serve an unlogged record are the parts of a security design that are difficult to retrofit, and they are present and working.

The weaknesses are concentrated where a deployment platform ordinarily supplies the control rather than the application. Transport encryption, secret management, backups, rate limiting and log aggregation are platform responsibilities that have not been built because the platform has not been chosen. The two application weaknesses that matter most are the absence of a second authentication factor and the absence of an amendment path for a signed record.

The review concludes that the system may proceed to user testing with synthetic data, subject to the remediation in Section 5.1 being completed and evidenced. It further concludes that no real clinical record may be entered until the remediation in Section 5.2 is complete and the outstanding data protection decisions are settled.

Table 6.1: Information Security Review Sign Off

Role	Name	Signature	Date
Prepared by, Software Engineering Intern			
Reviewed by, KMC ICT			
Compensating controls accepted by, Data Protection Owner			
Approved by, Head of Department, Quality, Health, Safety and Environment			